



Ver una cara no prueba una identidad

MFA verifica la cuenta. No verifica a la persona detrás de la cámara.

1

CUENTA AUTENTICADA

Lo que MFA sí verifica



Identidad digital

Se presentó una cuenta válida.



Autenticación

Se cumplieron credenciales y MFA.



Acceso condicionado

Cumplió políticas de acceso (Conditional Access).



Contexto del dispositivo

Cumplió el contexto de acceso requerido.

MFA aumenta la seguridad de la cuenta, no la identidad de la persona.

2

PERSONA APARENTE

Lo que NO verifica



Rostro

El video puede ser falso o manipulado.



Voz

La voz puede ser clonada o sintética.



Video en tiempo real

Puede ser generado por IA (deepfake).



Nombre mostrado

El nombre no confirma quién está realmente.

La apariencia audiovisual no es prueba de identidad.

3

AUTORIDAD PARA DECIDIR

Lo que la reunión
NO garantiza



Facultad

Puede que no tenga autoridad real.



Proceso requerido

Puede no seguir el flujo de aprobación.



Segunda validación

Puede requerir verificación adicional fuera de la reunión.



Evidencia de negocio

Puede requerir soportes independientes.

La videollamada transporta una conversación, no constituye prueba de autoridad.



MFA SÍ VERIFICA

- Que una cuenta autenticó correctamente.
- Que se cumplieron políticas de acceso.
- Que el dispositivo y el contexto son válidos.
- Que la sesión pertenece a esa identidad digital.



MFA NO VERIFICA

- Que el video sea auténtico.
- Que la voz sea auténtica.
- Que la persona en cámara sea quien inició sesión.
- Que la solicitud esté autorizada por el proceso de negocio.



Conclusión clave

Nunca asumir que ver una cara y escuchar una voz en Teams constituye **prueba de identidad**.



Identidad fuerte



Confianza del tenant



Validación fuera de banda



Controles operativos



Menor riesgo de suplantación

2 Quién puede entrar: identidad y control de acceso para reuniones sensibles

Reducir el riesgo comienza antes de la reunión:
controle identidades, dominios y métodos de acceso.



Modalidad de acceso	Identidad administrable	MFA / Conditional Access	Auditoría y revisión	Nivel de gobernabilidad	Uso recomendado para reuniones sensibles
 Anónimo (invite link) Participa sin iniciar sesión.	 No	 No	 Limitada	 Muy bajo	Evitar en reuniones sensibles
 Cuenta personal o no administrada Ej.: cuentas personales (Gmail, Outlook.com) o no administradas.	 Variable	 Variable	 Variable	 Bajo a medio	Restringir según política y nivel de sensibilidad
 Guest B2B (Entra External ID) Invitado gestionado desde su organización y aceptado en la suya.	 Sí	 Sí	 Sí	 Alto	Preferido para terceros recurrentes
 Usuario del tenant (Interno) Cuenta corporativa de la organización.	 Sí	 Sí	 Sí	 Alto	Participante interno controlado
 Dial-in telefónico Acceso por número telefónico.	 Menor contexto de identidad	 Condicionado por política	 Variable	 Bajo a medio	Deshabilitar o enviar a lobby en escenarios críticos

Postura recomendada para reuniones sensibles



Sobre dominios como gmail.com

No existe una opción única universal para "bloquear Gmail".
Utilice las políticas de colaboración externa (allow/block de dominios) según el tipo de identidad y colaboración que su organización permita.



Beneficios de esta postura



Menor riesgo de suplantación



Identidades verificables



Aplicación de políticas y controles



Auditoría y trazabilidad



Revisión y retiro de accesos



Mayor gobernabilidad, menor exposición



Recuerde

Una identidad autenticada reduce el riesgo de acceso no autorizado, pero no demuestra que la persona en cámara sea quien dice ser.

Siguiente infografía (3 de 4)

Qué puede ocurrir dentro de la reunión:
controles de sesión y protección del contenido.





3 Qué puede ocurrir dentro de la reunión

Controles para proteger la sesión y su contenido.
Reducen la exposición, pero **no eliminan el riesgo**.



1 PARTICIPACIÓN Y ACCESO



Lobby obligatorio

El organizador admite a cada participante.



Lista cerrada de invitados

Solo usuarios invitados o usuarios autenticados.



Solo el organizador o presentadores designados

Control de quién presenta contenido.



Restringir acceso telefónico

Desactivar "People dialing in can bypass lobby"



Evitar participantes anónimos

Bloquear o restringir participación anónima según la política.



2 APPS Y BOTS



Políticas de permisos de apps

Teams App Permission Policies y Teams App Setup Policies.



Allowlist de apps aprobadas

Permitir únicamente las apps y bots corporativos.



Revisión de bots en lobby

Detectar y revisar bots antes de admitirlos.



Bloquear apps in-meeting

Impedir que los participantes agreguen apps no aprobadas.



Acción ante apps/bots no esperados

Quitar, reportar y ajustar políticas según el incidente.



3 GRABACIÓN Y TRANSCRIPCIÓN



Control de grabación

Allow Recording = Off (si aplica) o solo el organizador puede grabar.



Control de transcripción

Allow Transcription = Off (si aplica) o solo el organizador puede transcribir.



Quién puede grabar/transcribir

Solo organizador y coorganizadores en reuniones sensibles.



Restringir copia y reenvío

Impedir copiar chat, captions y transcript al portapapeles.



Impedir reenvío de transcripts

Evitar que los transcripts se reenvíen fuera de la reunión.



4 PROTECCIÓN DE CONTENIDO



Etiquetas de sensibilidad

Aplicar sensibilidad y gobiernos automáticos (Purview).



Watermark en video y contenido

Aplicar marcas visibles para disuasión y trazabilidad.



Cifrado de extremo a extremo (E2EE)

Habilitar para reuniones críticas cuando sea requerido.



Restricciones sobre artefactos

Limitar descarga, impresión y almacenamiento de grabaciones.



Acceso a grabaciones y transcripts

Guardar en repositorios aprobados. Controlar quién puede acceder.



LÍMITES IMPORTANTES: ESTOS CONTROLES NO PUEDEN IMPEDIR COMPLETAMENTE



Fotos con otro dispositivo



Grabación local externa (OBS, etc.)



Captura de pantalla desde otra PC



Deepfake operado por cuenta legítima



Reproducción o copia fuera del canal



Fugas accidentales o maliciosas



REDUCE EXPOSICIÓN, NO ELIMINA EL RIESGO

Mantén controles técnicos + procedimientos + **validación fuera de banda**.



IDEA CLAVE

La plataforma protege la sesión.

El **riesgo residual** depende del comportamiento humano y de **validaciones** fuera de la reunión.

Trabaja en conjunto con:



Identidad fuerte (Infografía 2)



Validación fuera de banda (Infografía 4)

4 La reunión informa. El proceso autoriza.

Las decisiones sensibles requieren validación
fuera de banda e independiente de la videollamada.



1 SOLICITUD SENSIBLE RECIBIDA

Ejemplos:

- Pago o transferencia
- Acceso privilegiado
- Cambio bancario
- Firma de contrato
- Alta o cambio de proveedor
- Transferencia de información

Resultado
Se detiene la acción y se inicia el proceso de validación.

No actuar por urgencia. Desconfíe de solicitudes inesperadas.

2 PAUSA OBLIGATORIA

- No tome decisiones en la reunión.
- No use datos de contacto provistos durante la solicitud.
- Informe que se realizará validación por canales oficiales.

Resultado
Se evita el impulso y se reduce el riesgo de suplantación.

3 VALIDACIÓN FUERA DE BANDA

- Llame al número previamente registrado en directorio corporativo.
- Use canales aprobados (email/portal/canal alternativo ya acordado).
- Verifique la identidad y autoridad del solicitante.

Resultado
La identidad y la autoridad se verifican por un canal independiente.

4 SEGUNDA APROBACIÓN

- Aplique doble control o segregación de funciones.
- Confirme beneficiario, cuenta destino, monto y propósito.
- Obtenga aprobación independiente.

Resultado
La decisión cuenta con aprobación independiente y documentada.

5 REGISTRAR O RECHAZAR

- Documente la validación y la decisión.
- Guarde evidencia en el sistema oficial.
- Si hay inconsistencias, rechace la solicitud y escale al SOC o al equipo de seguridad.

Resultado
Decisión trazable, auditable y conforme al proceso.

Si una decisión no sobreviviría a una validación independiente, NO debe aprobarse durante la videollamada.

REGLA DE PROPIEDAD



Para conversaciones realmente sensibles, **la reunión debe ser organizada por el propietario de la información.**

Así puede controlar:



Lobby y lista de invitados



Roles y presentadores



Grabación y transcripción



Apps y bots permitidos



Sensitivity Labels (etiquetas)



Watermark en video y contenido



E2EE para reuniones críticas

Cuando la reunión es organizada por un tercero, estos controles quedan sujetos a sus políticas.



LÍMITES IMPORTANTES

Incluso con todos los controles, **NO podemos impedir:**



Fotos tomadas con otro dispositivo.



Grabación local externa (OBS, otra PC, etc.).



Captura de pantalla desde otra PC.



Deepfake operado por una cuenta legítima.



Reproducción o copia fuera del canal.

PRINCIPIOS CLAVE PARA DECISIONES DE ALTO VALOR



Desconfíe de solicitudes urgentes o inusuales.



Use siempre contactos oficiales preexistentes.



Aplique doble control obligatorio.



Documente y conserve evidencia de la decisión.



Segregue funciones para autorizar pagos y accesos.



Reporte eventos sospechosos de inmediato.



Nunca asumir que ver una cara y escuchar una voz en Teams constituye prueba de identidad.
Use Teams como canal de comunicación, no como mecanismo de autenticación o autorización.



Protección efectiva =



Identidad fuerte



Controles técnicos



Procedimientos robustos



+ Validación fuera de banda



LA ARQUITECTURA DE CONFIANZA DEL CORREO ELECTRÓNICO

Controles clave que trabajan juntos para proteger la identidad, el contenido y el transporte del correo.

EL NÚCLEO: AUTENTICIDAD DEL REMITENTE

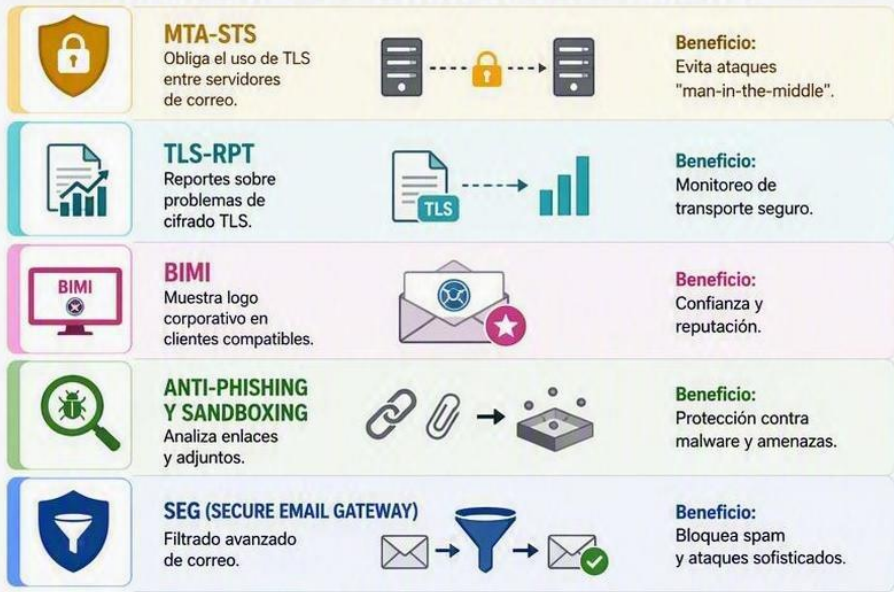
DMARC es la pieza que une SPF y DKIM y permite aplicar políticas.



DMARC utiliza los resultados de SPF y DKIM para tomar decisiones y generar reportes.

2

CONTROLES COMPLEMENTARIOS QUE FORTALECEN LA PROTECCIÓN



3

¿CÓMO TRABAJAN JUNTOS?



Los reportes (DMARC, TLS-RPT) y el monitoreo continuo permiten **mejorar la entrega legítima y reducir el fraude**.

Autenticidad • Integridad • Confidencialidad • Disponibilidad • Confianza
Una arquitectura de controles en capas protege su dominio, su marca y su negocio.





EL CAMINO HACIA DMARC REJECT SIN ROMPER EL NEGOCIO

Evoluciona tu protección paso a paso y minimiza el impacto operativo.

1

RUTA DE MADUREZ DMARC

Avanza de forma gradual y basada en datos.



CLAVE DEL ÉXITO: analizar reportes, identificar todos los emisores y corregir excepciones en cada etapa.

2

¿QUÉ PUEDE FALLAR AL ENDURECER DMARC?

Escenarios reales que pueden interrumpir comunicaciones legítimas.

CASO 1

Sistemas legítimos mal configurados



Si estos sistemas no están incluidos en SPF o no firman con DKIM:

! Los mensajes pueden ser rechazados.

Impacto:

- Órdenes de compra no llegan.
- Facturas se pierden.
- Alertas operativas no son entregadas.
- Reclamos de clientes quedan sin respuesta.

CASO 2

Reenvío de correos (Forwarding)



El reenviador modifica la ruta.

- 1 SPF falla.
- 2 Si DKIM también falla por modificaciones al mensaje, DMARC falla.
- 3 El correo puede ser rechazado.

CASO 3

Aplicaciones heredadas



Estos sistemas suelen:

- ✓ No firmar DKIM.
- ✓ No soportar TLS moderno.
- ✓ Enviar directamente por SMTP.

Cuando tus clientes endurecen DMARC:
➔ dejan de poder enviar notificaciones.

3

BENEFICIOS QUE PROTEGEN VS RIESGOS QUE DEBES GESTIONAR



4

BUENAS PRÁCTICAS PARA UNA ADOPCIÓN SEGURA



Objetivo: Protección máxima contra suplantación de identidad sin romper las comunicaciones legítimas con socios comerciales menos robustos.

5



MENSAJE CLAVE

El mayor desafío no es implementar SPF, DKIM o DMARC; es descubrir todos los sistemas internos y de terceros que envían correo en nombre del dominio antes de endurecer las políticas.



ESTA SERIE EN 2 INFOGRAFÍAS



1 La Arquitectura de Confianza del Correo Electrónico
Controles y capacidades clave que trabajan juntos.



2 El Camino hacia DMARC Reject sin Romper el Negocio
Estrategia, riesgos y buenas prácticas para una adopción segura.

